05-RISK-ASSESSMENT.md

.things that Matter

Risk Assessment & Mitigation Plan

Document Information	
Company Name	.things that Matter
Document Type	Risk Assessment
Version	1.0
Date	January 21, 2026
Author	Matome Mboweni, CTO

1. Risk Management Overview

1.1 Risk Assessment Framework

Probability	Definition
High (H)	>70% likely to occur
Medium (M)	30-70% likely to occur
Low (L)	<30% likely to occur

Impact	Definition
Critical	Project failure, major pivot required
High	Significant delay (>4 weeks), budget overrun >20%
Medium	Moderate delay (2-4 weeks), budget impact 10-20%
Low	Minor delay (<2 weeks), minimal budget impact

1.2 Risk Matrix

	Low Impact	Medium Impact	High Impact	Critical
High Prob	Monitor	Mitigate	Mitigate	Avoid
Medium Prob	Accept	Monitor	Mitigate	Mitigate
Low Prob	Accept	Accept	Monitor	Mitigate

2. Risk Register

2.1 Technical Risks

ID	Risk	Probability	Impact	Score	Category
T01	Steganography fails on major platforms	Medium	Critical	**High**	Technical
T02	CLIP API becomes too expensive	Low	High	Medium	Technical
T03	FlatBuffers schema design flaws	Low	High	Medium	Technical
T04	Ed25519 implementation vulnerability	Low	Critical	Medium	Security

```
| T05 | Browser extension rejected by Chrome | Low | High | Medium | Technical |
| T06 | WASM performance insufficient | Low | Medium | Low | Technical |
| T07 | Rust learning curve steeper than expected | Medium | Low | Low | Technical |
| T08 | Cloudflare R2 service disruption | Low | Medium | Low | Infrastructure |
```

2.2 Business Risks

```
| ID | Risk | Probability | Impact | Score | Category |
|----|------|-------------|--------|-------|----------|
| B01 | No merchant adoption | Medium | Critical | **High** | Business |
| B02 | Budget overrun | Medium | High | **High** | Financial |
| B03 | Solo developer burnout | Medium | High | **High** | Resource |
| B04 | Competitor launches similar product | Low | Medium | Low | Market |
| B05 | Legal challenge to steganography | Low | High | Medium | Legal |
| B06 | Scope creep | High | Medium | **High** | Management |
```

2.3 Operational Risks

```
| ID | Risk | Probability | Impact | Score | Category |
|----|------|-------------|--------|-------|----------|
| O01 | Cursor Pro limits slow development | Medium | Medium | Medium | Operational |
| O02 | Free tier services become insufficient | Medium | Medium | Medium | Infrastructure |
| O03 | Key dependency (Replicate) changes API | Low | High | Medium | Dependency |
| O04 | Data loss (code, artifacts) | Low | Critical | Medium | Operational |
| O05 | Security breach before audit | Low | Critical | Medium | Security |
```

3. Detailed Risk Analysis

3.1 T01: Steganography Platform Failure

\1 Steganographic payloads do not survive on major social platforms.

```
| Attribute | Value |
|-----------|-------|
| Probability | Medium (40-60%) |
| Impact | Critical |
| Risk Score | **HIGH** |
| Risk Owner | CTO |
```

\1
- Instagram, Twitter, Facebook all strip XMP metadata and recompress images
- EOF appended data destroyed during platform processing
- Survival rate <50% across tested platforms

\1
- Phase 0 testing shows <50% survival
- Major platforms (Instagram, Twitter) show 0% survival
- Only minor platforms (Discord, Telegram) preserve data

\1

```
| Strategy | Action | Effort |
|----------|--------|--------|
| **Validate Early** | Phase 0 testing on 20 platforms before committing | 4 weeks |
| **Hybrid Distribution** | If steg fails, prioritize matter:// URIs | Parallel dev |
| **Metadata Focus** | If EOF fails, rely on XMP gist only | Design change |
| **Platform-Specific** | Different strategies per platform | +2 weeks |
```

\1
If steganography survival <50%:
1. Pivot to matter:// URI as primary distribution
2. Use polyglot images only for platforms that support them
3. Build URL shortener service for matter:// links
4. Focus on "link in bio" use cases

\1 Medium (after mitigation)

3.2 B01: No Merchant Adoption

\1 Merchants do not see value in .thing files and refuse to onboard.

```
| Attribute | Value |
|-----------|-------|
| Probability | Medium (30-50%) |
| Impact | Critical |
| Risk Score | **HIGH** |
| Risk Owner | CEO |
```

\1
- Merchants don't understand the value proposition
- Integration effort seems too high
- No clear ROI demonstrated
- Competition from established platforms

\1
- <3 merchants interested after 2 months outreach
- Beta merchants churn before launch
- Feedback indicates confusion about value

\1

```
| Strategy | Action | Effort |
|----------|--------|--------|
| **Developer First** | Target developers who build merchant tools | Strategy shift |
| **Open Source** | Release compiler open-source for community adoption | Month 3 |
| **Demo-Driven** | Build compelling demos before outreach | Ongoing |
| **Niche Focus** | Target specific verticals (NFTs, digital goods) | Research |
```

\1
If merchant adoption fails:
1. Pivot to B2D (business-to-developer) model
2. Open-source everything immediately
3. Focus on building community
4. Seek partnership with e-commerce platforms (Shopify, WooCommerce)

\1 Medium (after mitigation)

3.3 B02: Budget Overrun

\1 Actual costs exceed R72,000 budget.

Attribute	Value
Probability	Medium (40-50%)
Impact	High
Risk Score	**HIGH**
Risk Owner	CTO + CEO

\1
- CLIP API costs higher than projected
- Need to upgrade from free tiers earlier
- Unexpected tools or services required
- 5% buffer insufficient

\1
- Monthly spend exceeds projection by >20%
- CLIP usage higher than estimated
- Free tier limits hit early
- Contingency depleted by Month 6

\1

Strategy	Action	Effort
Track Weekly	Monitor expenses vs. budget weekly	Ongoing
Cost Alerts	Set up billing alerts on all services	1 day
Usage Optimization	Cache CLIP results, batch requests	Design
Free Tier Discipline	Stay on free tiers as long as possible	Discipline

\1

Expense	Budget	Hard Limit	Action if Exceeded
CLIP API	R21,600	R25,000	Reduce batch sizes
R2 Storage	R7,560	R10,000	Compress more aggressively
Development Tools	R6,048	R7,000	Drop optional tools
Total	R72,000	R80,000	Pause non-critical work

\1
If budget exhausted:
1. Pause development, seek additional funding
2. Reduce scope to MVP only
3. Release open-source, seek community contributions
4. CEO to explore bridge funding

\1 Medium (after mitigation)

3.4 B03: Solo Developer Burnout

\1 Single developer experiences burnout, affecting delivery.

Attribute	Value
Probability	Medium (40-50%)
Impact	High
Risk Score	**HIGH**
Risk Owner	CTO + CEO

\1

- 11-month solo development becomes overwhelming
- No time off, constant pressure
- Health issues arise
- Quality degrades due to fatigue

\1
- Missing weekly commitments
- Declining code quality
- Communication becomes sparse
- Expressed frustration or exhaustion

\1

Strategy	Action	Effort
Sustainable Pace	Strict 30 hrs/week limit	Discipline
Weekly Rest	No coding on Sundays	Policy
Milestone Celebrations	Acknowledge each 15% increment	Morale
Open Communication	CEO checks in on wellbeing	Weekly

\1

- [ ] 30 hours/week maximum
- [ ] One full day off per week
- [ ] No late-night coding sessions
- [ ] Exercise/breaks scheduled
- [ ] Vacation days planned (at least 1 week)
- [ ] CEO check-ins on wellbeing

\1
If burnout occurs:
1. Immediate 1-2 week break
2. Adjust timeline (add 1-2 months)
3. Reduce scope if needed
4. CEO to explore contractor support

\1 Low (after mitigation)

3.5 B06: Scope Creep

\1 Continuous feature additions delay delivery.

Attribute	Value
Probability	High (60-70%)
Impact	Medium
Risk Score	**HIGH**
Risk Owner	CTO

\1
- "Just one more feature" syndrome
- Feedback leads to constant pivots
- Perfectionism delays launch
- Phase 2 features creep into Phase 1

\1
- Feature list grows after Phase 0
- Milestones consistently missed
- "Almost done" state persists
- Technical debt accumulates

\1

Strategy	Action	Effort
Feature Freeze	Lock features after Phase 0 validation	Policy
MVP Mindset	Ship minimal viable, iterate later	Discipline
Parking Lot	Document "nice to haves" for Phase 2	Process
Weekly Scope Review	CEO/CTO review scope weekly	30 min/week

\1

1. All features documented in PRD
2. New requests go to "Phase 2 Parking Lot"
3. Only security/blocking bugs added post-freeze
4. CEO approval required for any scope change

\1 Low (after mitigation)

3.6 T05: Chrome Extension Rejection

\1 Chrome Web Store rejects the extension.

Attribute	Value
Probability	Low (20-30%)
Impact	High
Risk Score	**Medium**
Risk Owner	CTO

\1
- Extension violates Chrome policies
- "Manipulating page content" flagged
- Permission requests deemed excessive
- Review process delayed

\1
- Rejection email from Chrome
- Policy violation cited
- Required changes significant

\1

Strategy	Action	Effort
Policy Review	Study Chrome extension policies early	1 day
Minimal Permissions	Request only essential permissions	Design
Transparent Description	Clear store listing explaining functionality	2 hours
Firefox Backup	Simultaneously submit to Firefox Add-ons	+1 week

\1
If Chrome rejects:

1. Appeal with detailed explanation
2. Modify extension to comply
3. Launch on Firefox first
4. Consider side-loading / enterprise distribution

\1 Low (after mitigation)

3.7 O01: Cursor Pro Limits

\1 Cursor Pro's 500 fast requests/month limit slows development.

```
| Attribute | Value |
|-----------|-------|
| Probability | Medium (50-60%) |
| Impact | Medium |
| Risk Score | **Medium** |
| Risk Owner | CTO |
```

\1
- Intensive coding sessions deplete quota mid-month
- Slow requests are too slow for iterative development
- Productivity drops 20-30% during heavy coding

\1
- Hitting quota warnings
- Resorting to slow requests frequently
- Frustration with tool limitations

\1

```
| Strategy | Action | Effort |
|----------|--------|--------|
| **Batch Work** | Plan intensive work for start of month | Discipline |
| **Slow Request Usage** | Use slow requests for routine tasks | Habit |
| **Manual Coding** | Fall back to manual when quota depleted | Skill |
| **Upgrade Trigger** | If productivity <70%, request Ultra budget | Decision |
```

\1

```
| Situation | Action |
|-----------|--------|
| Hitting limit occasionally | Continue with workarounds |
| Hitting limit every month | Evaluate Ultra upgrade |
| Productivity <70% | Request Ultra budget from CEO |
```

\1 Low (after mitigation)

3.8 O05: Security Breach Before Audit

\1 Security vulnerability exploited before formal audit.

```
| Attribute | Value |
|-----------|-------|
| Probability | Low (15-25%) |
| Impact | Critical |
```

| Risk Score | **Medium** |
| Risk Owner | CTO |

\1
- Ed25519 implementation has subtle flaw
- Key management vulnerability
- API injection attack
- Merchant/user data exposed

\1
- Unusual API activity
- Reports of invalid signatures
- Data access from unknown sources

\1

Strategy	Action	Effort
Library Usage	Use well-audited crypto libraries (ed25519-dalek)	Design
Self Review	Thorough code review of all security code	Ongoing
Open Source	Community review once open-sourced	Month 3
Minimal Data	Don't store sensitive user data	Design
Bug Bounty	Consider informal bug bounty post-launch	Launch

\1

- [ ] Use audited crypto libraries only
- [ ] No custom crypto implementations
- [ ] Input validation on all endpoints
- [ ] No secrets in code/logs
- [ ] HTTPS everywhere
- [ ] Rate limiting on APIs
- [ ] Key rotation plan documented

\1
If breach occurs:
1. Immediate incident response
2. Rotate all keys
3. Notify affected parties
4. Post-mortem and fix
5. Accelerate formal audit

\1 Low (after mitigation)

4. Risk Response Summary

4.1 Risks to Avoid

Risk	Avoidance Strategy
Scope creep	Feature freeze policy
Budget overrun	Weekly tracking, hard limits

4.2 Risks to Mitigate

```
| Risk | Mitigation Strategy |
|------|---------------------|
| Steganography failure | Phase 0 validation, hybrid approach |
| No merchant adoption | Developer-first, open source |
| Burnout | Sustainable pace, rest policy |
| Security breach | Library usage, self-review, open source |
```

4.3 Risks to Monitor

```
| Risk | Monitoring Approach |
|------|---------------------|
| CLIP API costs | Weekly spend review |
| Free tier limits | Usage dashboards |
| Chrome policies | Policy change alerts |
| Competitor activity | Market monitoring |
```

4.4 Risks to Accept

```
| Risk | Rationale |
|------|-----------|
| Rust learning curve | C/C++ background accelerates learning |
| WASM performance | Can optimize later |
| Minor platform incompatibility | Focus on major platforms |
```

5. Risk Monitoring Plan

5.1 Weekly Risk Review

Every Friday:
- [ ] Review active risks
- [ ] Check indicators
- [ ] Update risk scores if needed
- [ ] Report high risks to CEO

5.2 Monthly Risk Report

First Monday of month:
- [ ] Full risk register review
- [ ] Update mitigation progress
- [ ] Identify new risks
- [ ] Adjust strategies

5.3 Phase Gate Reviews

At each milestone:
- [ ] Comprehensive risk assessment
- [ ] Go/No-Go decision
- [ ] Risk-adjusted timeline
- [ ] Budget impact analysis

6. Escalation Matrix

Risk Level	Response Time	Escalation To
Critical	Immediate	CEO
High	Within 24 hours	CEO
Medium	Within 1 week	Weekly report
Low	Monthly review	Monthly report

7. Document Approval

Role	Name	Signature	Date
CEO	Sobuhle Nyambali	_____	___/___/2026
CTO	Matome Mboweni	_____	___/___/2026

\1 1.0
\1 January 21, 2026
\1 Monthly